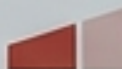


Autópsia de Vulnerabilidade e Exposição no Código-Fonte

System Tag

VULNERABILIDADE:	SEC-TC-F01
ALVO:	98.95.207.28
VETOR:	Camada de Apresentação HTTP
SEVERIDADE:	MÉDIA (CVSS: 3.1 / Score: 5.3) 

A Superfície de Ataque Mapeada na Porta 80

DADOS DO ALVO

Organização:
TechCorp Solutions

Endereço IPv4:
98.95.207.28

Vetor de Entrada:
Camada HTTP (Porta 80)

Alvo Específico:
Endpoint Raiz (/)

Internet Pública



Porta 80

Servidor Web



HTTP Response

A fase de reconhecimento ativo revelou que o servidor web entrega respostas HTTP contendo metadados e comentários de depuração da fase de desenvolvimento. Uma brecha clássica de exposição passiva de informações estruturais.

Prova de Conceito via Inspeção Dinâmica

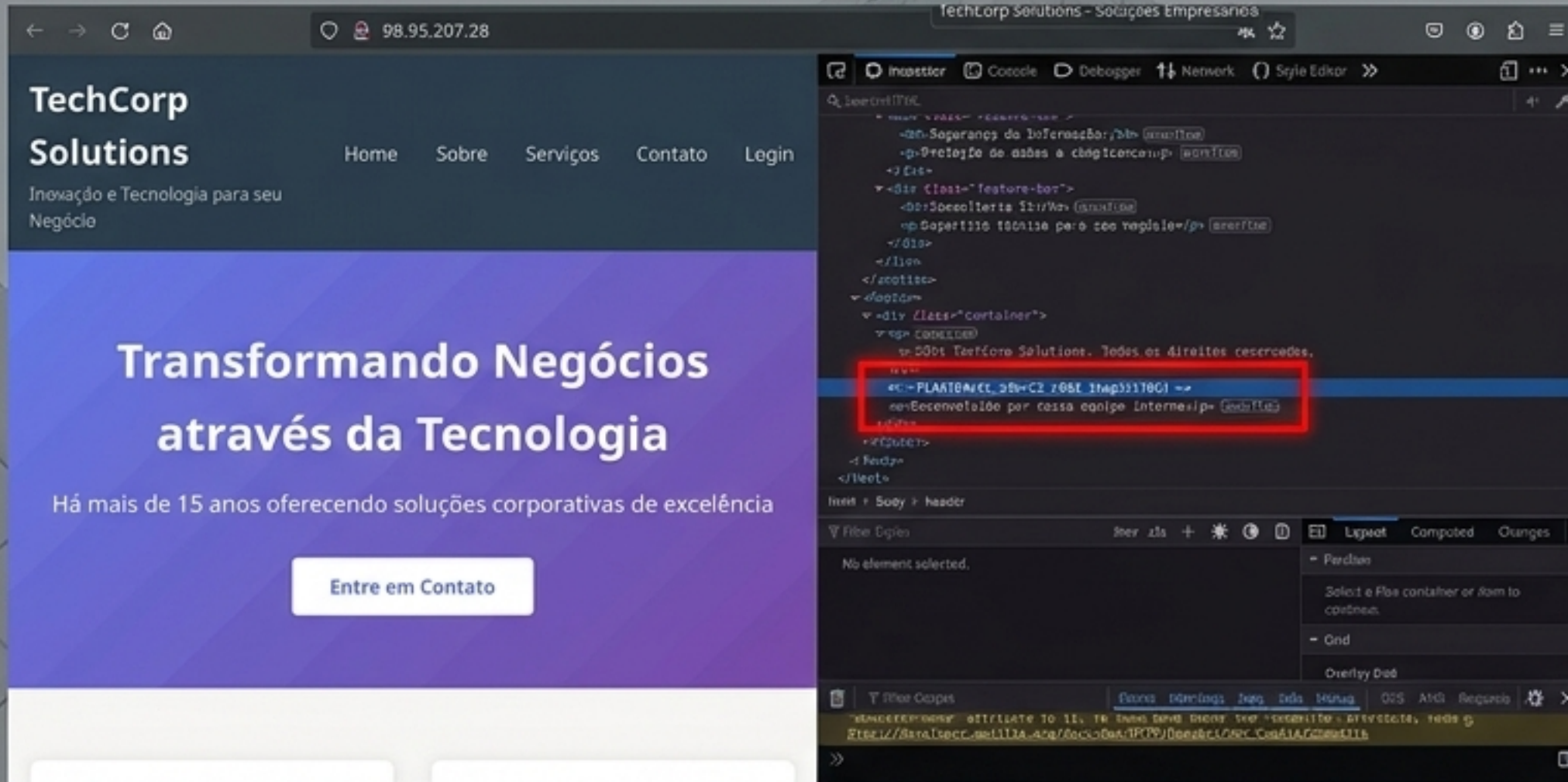
“As brechas mais perigosas nem sempre precisam de ferramentas complexas.”



```
# Execução de requisição HTTP automatizada para extração do DOM  
$ curl -s http://98.95.207.28/ | grep "FLAG"
```

Uma simples requisição via curl ignora completamente a renderização visual do navegador e expõe a estrutura bruta e irrestrita do Document Object Model (DOM), revelando anotações esquecidas.

O Segredo Oculto no Rodapé da Aplicação



Artefato Extraído

```
<!--  
FLAG{b4s1c_s0urc3_c0d3_1nsp3ct10n}  
-->  
<p>Desenvolvido por nossa equipe  
interna</p>
```

A inspeção técnica do elemento `<footer>` confirma o vazamento do token de integridade e anotações diretas da equipe de desenvolvimento em pleno ambiente de produção.

Matriz de Impacto: O Custo da Desatenção

IMPACTO TÉCNICO

Exposição Arquitetural: Divulgação inadvertida de dados e histórico de desenvolvimento.

Perda de Integridade: Comprometimento de artefatos de teste e tokens de validação operacional.

Mapeamento de Superfície: Fornecimento de vetores e contexto direto para ataques subsequentes muito mais complexos.

IMPACTO DE NEGÓCIO

Quebra da Postura de Segurança: A total ineficácia do modelo de segurança por obscuridade.

Riscos Operacionais: Facilitação drástica para engenharia social e o reconhecimento direcionado contra a infraestrutura e os colaboradores da empresa.

A Ilusão da Segurança por Obscuridade

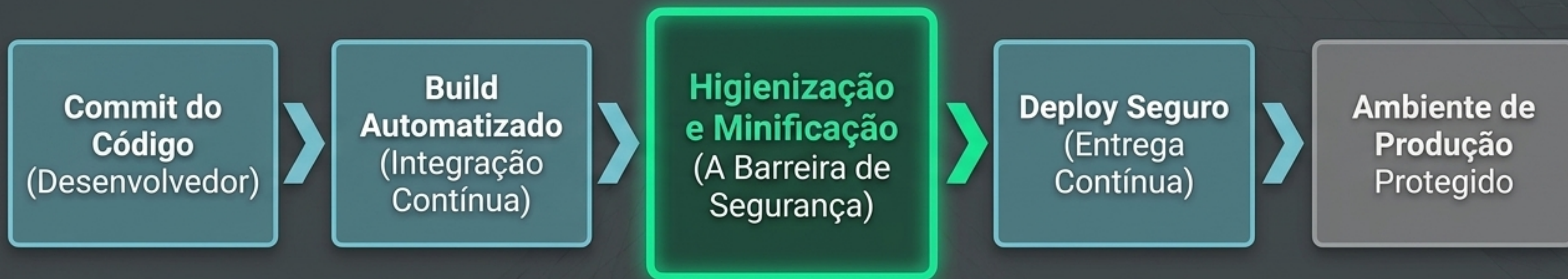


“Deixar comentários de debug e flags no HTML de produção é como instalar uma porta blindada de última geração... e colar a senha do alarme com fita adesiva no vidro da janela.”

A falha humana é inevitável no desenvolvimento de software. A proteção deve ser sistêmica.

Remediação Sistêmica via Pipeline DevSecOps

A solução não é auditar e apagar comentários manualmente, mas eliminar a falha humana através da automação estrutural.



Ao automatizar a limpeza do HTML no momento do deploy, garantimos que anotações internas nunca se transformem em mapas do tesouro para invasores.

O Padrão Ouro de Deploy com html-minifier

Implementação da biblioteca padrão da indústria ([html-minifier](#)) como etapa mandatória de pré-deploy.

Arquivo: `.htmlminifierrc`

```
{  
  "removeComments": true,  
  "collapseWhitespace": true,  
  "minifyJS": true,  
  "minifyCSS": true,  
  "removeRedundantAttributes": true  
}
```

A diretiva de configuração `"removeComments": true` atua como uma barreira arquitetural imutável. Ela varre o DOM e extrai forçosamente qualquer flag, token, ou anotação de desenvolvedor antes mesmo do código atingir o cliente.

Segurança Integrada Desde a Concepção



Visibilidade: O reconhecimento ativo da porta 80 mapeou o vazamento passivo via DOM.



Prova Escalonada (PoC): Uma requisição simples de terminal extraiu a flag estratégica sem gerar atrito.



Solução Sistêmica Aplicada: Adoção imediata de .htmlminifierrc na esteira CI/CD para bloqueio definitivo.

O objetivo do pentest não é apenas consertar o código de hoje, mas blindar o processo de desenvolvimento de amanhã.